Criptografía y Seguridad

Criptografía:
Cifrado

Criptosistema (repaso)

Es una terna de algoritmos

Gen: $() \rightarrow K$	Generador de clave
Enc: $K \times P \rightarrow C$	Cifrado
Dec: $K \times C \rightarrow P$	Descifrado

Propiedad básica:

Para todo m y k válidos: $d_k(e_k(m))=m$

Conjuntos involucrados:
K, espacio de claves es el conjunto de todas las <u>claves</u> posibles
P, espacio plano, es el conjunto de todos los <u>mensajes</u> posibles
C, espacio cifrado, es el conjunto de todos los <u>mensajes cifrados</u> posibles

Secreto perfecto (repaso)

Dado un criptosistema: Gen, e y d

El criptosistema posee secreto perfecto si para toda distribución de probabilidades en M, cada mensaje m y cada mensaje cifrado c tal que $Pr[C = c] > 0$:

$$Pr[M=m \mid C = c] = Pr[M=m]$$

La paradoja del secreto perfecto:
Notar que $c=e_k(m)$, así que las variables aleatorias discretas C y E son dependientes. Sin embargo, la propiedad de secreto perfecto interpretada probabilísticamente dice que son V.A.D.s independientes.

One Time Pad

Atribuido a Verman (1917)

Gen: $k \leftarrow \{0, 1\}^n$, $n=|m|$

Enc: $e_k(m) = m \oplus k$

Dec: $d_k(c) = c \oplus k$

Ejemplo:

m=	0	0	1	0	1	1	0	1	0	0	0	1	0	1	1	1	0
k=	0	1	1	0	0	1	1	1	0	1	0	0	1	1	0	1	0
c=	0	1	0	0	1	0	1	0	0	1	0	1	1	0	1	0	0

Propiedad fundamental del OTP

El OTP tiene secreto perfecto

Demostración (1)

¿El OTP tiene secreto perfecto?

Para cualquier par (m, c) de longitud n, $|k|=2^n=N$

Queremos probar: $P(M=m|C=c)=P(M=m)$

Lema 1:

$P(C=c) = Sum_k(P(C=c \cap K=k))$

k y m se eligen independientemente

$$P(C = c \cap K = k) = P(M = c \oplus k \cap K = k)$$

$$= P(M = c \oplus k) * P(K = k)$$

$$= P(M = c \oplus k) * (1/N).$$

$P(C=c) = (1/N) * Sum_k(P(M = c \oplus k))$

Pasamos por todos los valores de m. La suma de las probabilidades da 1|

$P(C=c) = (1/N)$

Demostración (2)

¿El OTP tiene secreto perfecto?

Para cualquier par (m, c) de longitud n, $|k|=2^n=N$

$$P(M = m \mid C = c) * P(C = c) = P(C = c \cap M = m)$$

$$= P(K = c \oplus m \cap M = m)$$

$$= P(K = c \oplus m) * P(M = m)$$

$$P(M = m \mid C = c) * (1/N) \quad = (1/N) * P(M = m)$$

$$P(M = m \mid C = c) = P(M = m)$$

One Time Pad

Las malas noticias

- Secreto perfecto => $|K| >= |C|$
- Si una clave se utiliza 2 veces:
  - $c_1 = m_1 \oplus k$
  - $c_2 = m_2 \oplus k$
  - $\Rightarrow c_1 \oplus c_2 = m_1 \oplus m_2$
  - Se pierde el secreto perfecto
- La clave seleccionada DEBE ser aleatoria
  - ¿Cómo puede garantizarse esto?

One Time Pad

¿Por qué la clave debe ser aleatoria?

Ejercicio

Considerar una clave no aleatoria:

$P(k=00) = 0.3$ y $P(k=01) = 0.1$

$P(k=10) = 0.4$ y $P(k=11) = 0.2$

Si la distribución del texto plano es:

$P(m=00) = 0.60$ $P(m=01) = 0.15$

$P(m=10) = 0.10$ $P(m=11) = 0.15$

Y se obtiene un mensaje C=01

¿Que probabilidades hay que M=00)

Ejercicio

Queremos calcular P(m=00 | c=01).

Estadísticamente M y C no son independientes:

$P(M=x \mid C=y) * P(C=y) = P(C=y \mid M=x) * P(M=x)$

$P(M=00 \mid C=01) * \mathbf{P(C=01)} = \mathbf{P(C=01 \mid M=00)} * P(M=00)$

$\mathbf{P(C=01)} = \mathrm{Sum}_k(P(C=01 \cap K=k))$

$= \mathrm{Sum}_k(P(M=01 \oplus k) * P(K=k))$

$= P(M=01)*P(K=00) + P(M=00)*P(K=01) +$

$P(M=11)*P(K=10) + P(M=10)*P(K=11)$

$= 0.15 * 0.3 + 0.6 * 0.1 + 0.15 * 0.4 + 0.1 * 0.2$

$= \mathbf{0.185}$

Ejercicio

P(C=01 | M=00) = P(K= 01 * M | M = 00) = P(K = 01) **= 0.1**

Juntando todo:

P(M=00 | C=01) * **P(C=01)** = **P(C=01 | M=00)** * P(M=00)

P(M=00 | C=01) * 0.185 = 0.1 * 0.6

P(M=00 | C=01) = 0.32

P(M=00 | C=01) = 0.32 != P(M=00) = 0.6

Más allá del OTP

Resultado teóricos interesantes

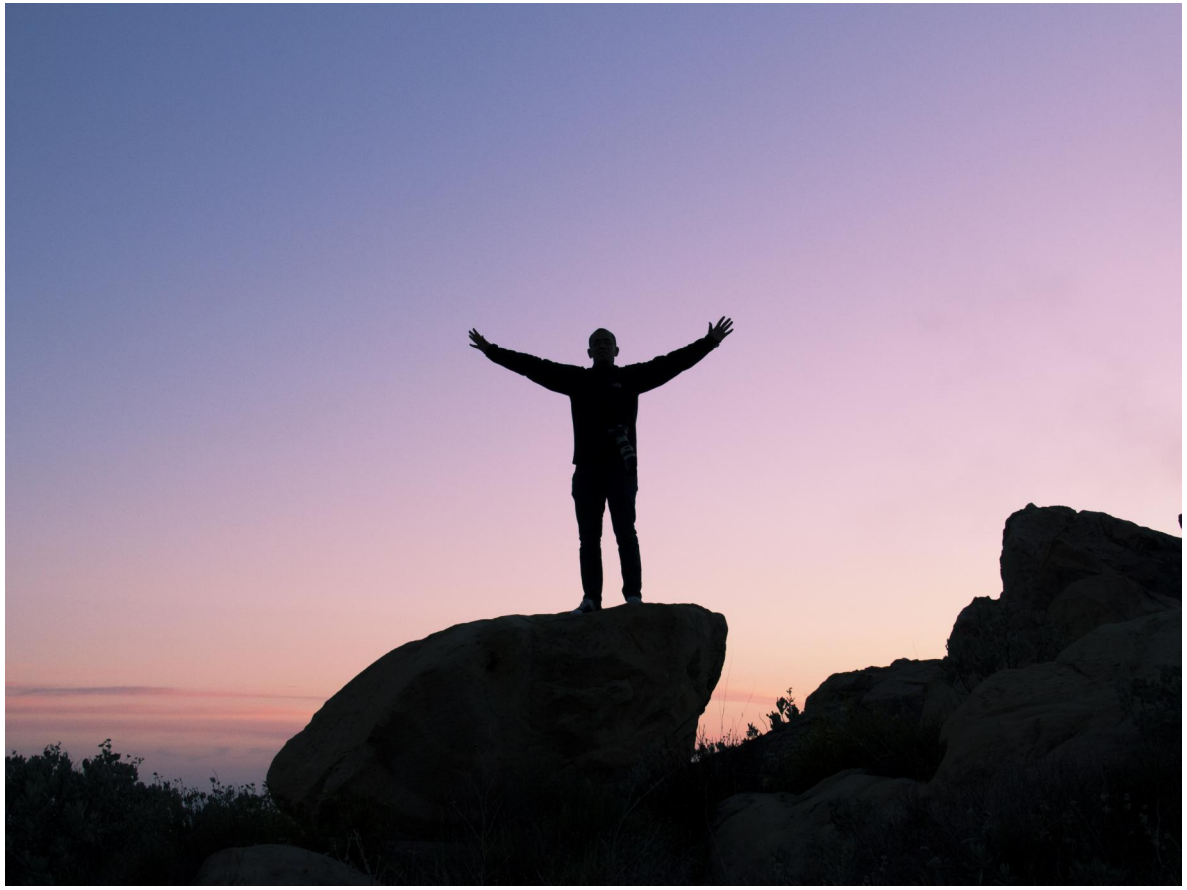
- Cualquier criptosistema con secreto perfecto es reducible al OTP
- Cualquier sistema que no sea reducible al OTP no posee secreto perfecto

Consecuencias

- El secreto perfecto es demasiado impráctico
- Necesitamos otras construcciones

Seguridad Computacional

Secreto perfecto = Seguridad incondicional



Seguridad Computacional

Secreto perfecto = Seguridad incondicional

- Limitar escenarios
- Limitar garantías

Seguridad computacional

Seguridad Computacional

Garantizar seguridad solo contra adversarios “limitados”

Asume un límite en los recursos del atacante (especialmente tiempo).

Aceptar una pequeña probabilidad de éxito para el atacante

Se deja de lado la infalibilidad

Criptosistemas de flujo

Intercambian la clave del OTP por la salida de un generador pseudoaleatorio:

Gen: $k \leftarrow K$

Enc: $e_k(m) = G(k) \oplus m$

Dec: $d_k(c) = G(k) \oplus c$

La **gran diferencia**: $|K| <<< |M|$

Por ejemplo: $|K| = 2^{128}$, $|M| = |K|^{128}$

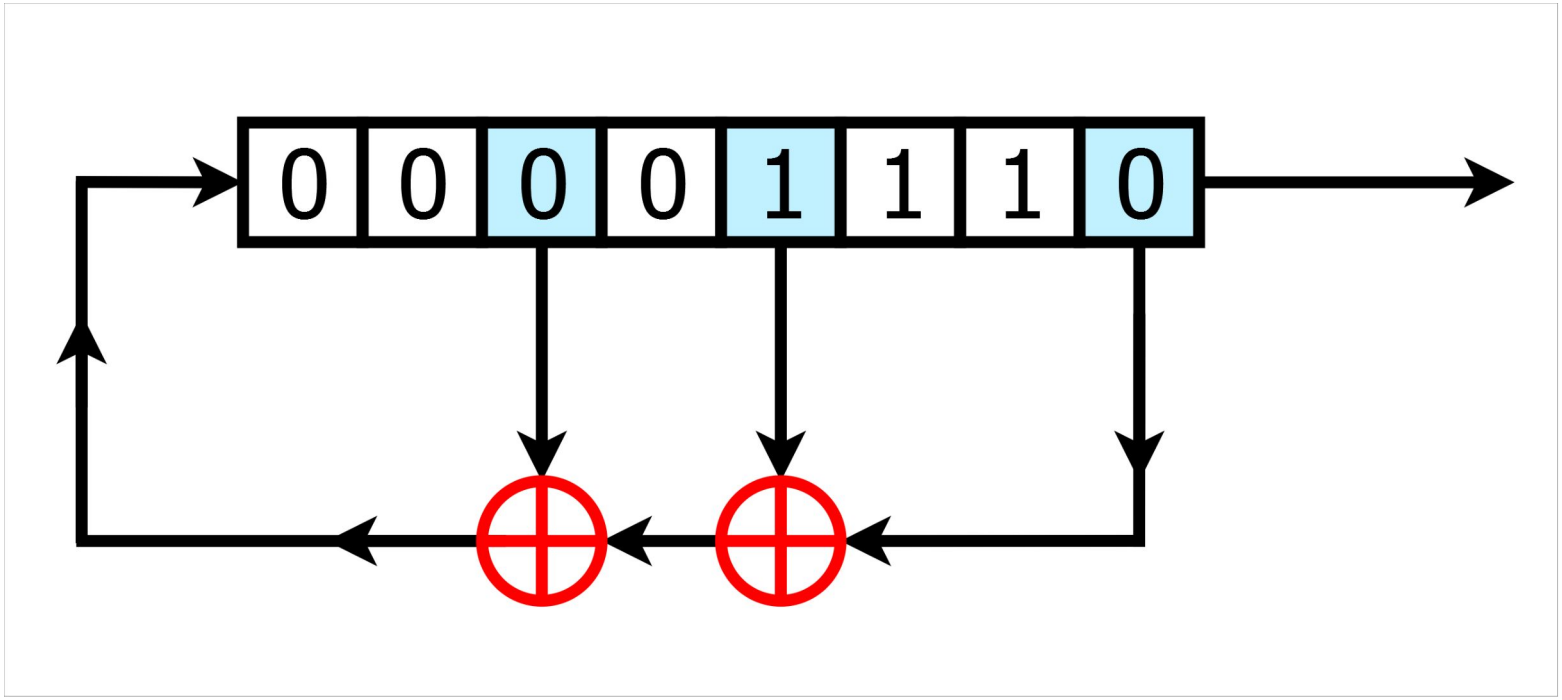
Generadores pseudoaleatorios

Son algoritmos determinísticos

Expanden una entrada llamada semilla (*seed*)

La salida parece aleatoria

Ejemplo:



Generadores pseudoaleatorios

Formalmente:

Sea $D = \{ f: \{0,1\}^n \rightarrow \{0,1\} \}$ una familia de funciones

$G: \{0,1\}^s \rightarrow \{0,1\}^n$, con $s < n$ es un generador pseudoaleatorio con respecto a D si:

Para toda f en D:

$$P(f(G(r^s)) \neq f(r^n)) = \varepsilon$$

Probabilidad generalizada

Secuencia realmente aleatoria

Valor despreciable

Ejemplo

Sea s = { 1, …, 10 }

$G(s) = \{ G_0 \% 2, G_1 \% 2, G_2 \% 2, \ldots, G_n \% 2\}$

$G_0 = s$

$G_i = G_{i-1} * 3 + 1 \bmod 11$

Generar 5 bits con s = 2

Generar 5 bits con s = 6

Criptosistemas de flujo

Intercambian la clave del OTP por la salida de un generador pseudoaleatorio:

Gen: $k \leftarrow K$

Enc: $e_k(m) = G(k) \oplus m$

Dec: $d_k(c) = G(k) \oplus c$

¿Cómo medimos la seguridad del criptosistema ?

Pruebas de seguridad

- Prueban características de un criptosistema
- Son una serie de pasos que prueban un algoritmo (que representa un ataque)
- El atacante gana o pierde la prueba
- Se puede repetir múltiples veces
  - Interesa la probabilidad de éxito del atacante

Prueba de indistinguibilidad

Eavesdropping Indistinguishability test: $Eav_{A,\Pi}$

Dado un adversario A, y un Criptosistema Π:

1) A genera m_0 y m_1 arbitrariamente
2) Se genera una clave $k \leftarrow K$
3) Se genera $b \leftarrow \{ 0, 1 \}$
4) A recibe $c = e_k(m_b)$
5) A emite $b' = \{ 0, 1\}$

$Eav_{A,\Pi} = 1$ si $b = b'$ (A gana)

Si $Pr[Eav_{A,\Pi}=1] = 0{,}5 + \varepsilon \Rightarrow \Pi$ es indisting.

Nivel de seguridad

Nivel de seguridad

- Está dado por una variable
- Relaciona la cota en el poder de un adversario y la probabilidad de éxito que tendrá

Dado un nivel de seguridad n se espera que:

- Un adversario corra algoritmos de orden PPT(n) (Probabilistic Polinomial Time)
- La probabilidad de éxito sea una función despreciable en n:

$$\varepsilon(n) \text{ es despreciable} \leftrightarrow \lim \varepsilon(n) < 1 / n^k$$

Prueba de indistinguibilidad

Eavesdropping Indistinguishability test: $Eav_{A,\Pi}$

Dado un adversario A(n), y un Criptosistema Π(n)):

1) A genera m_0 y m_1 arbitrariamente
2) Se genera una clave $k \leftarrow K$
3) Se genera $b \leftarrow \{ 0, 1 \}$
4) A recibe $c = e_k(m_b)$
5) A emite $b' = \{ 0, 1\}$

$Eav_{A,\Pi} = 1$ si $b = b'$ (A gana)

Si $Pr[Eav_{A,\Pi}=1] = 0{,}5 + \varepsilon(n)$ => Π es indisting.

Criptosistemas de flujo

Intercambian la clave del OTP por la salida de un generador pseudoaleatorio:

Gen: $k \leftarrow K$

Enc: $enc_k(m) = G(k) \oplus m$

Dec: $dec_k(c) = G(k) \oplus c$

Teorema:

Si G(.) es un generador pseudoaleatorio entonces el criptosistema es indistinguible ante observadores

Ejercicio

Demostrar que si es posible distinguir G(.) de una secuencia aleatoria un criptosistema de flujo basado en G no pasa la prueba EAV

Múltiples cifrados

Multiple message eavesdropping test: $Mul_{A,\Pi}$

Dado un adversario A, y un Criptosistema Π:

1) A genera $(m_{00}, m_{01}, \ldots, m_{0i})$ y $(m_{10}, m_{11}, \ldots, m_{1i})$
2) Se genera una clave $k \leftarrow K$
3) Se genera $b \leftarrow \{ 0, 1 \}$
4) A recibe $(c_0, c_1, \ldots, c_i)$, donde $c_j = Enc_k(m_{bj})$
5) A emite $b' = \{ 0, 1\}$

$Mul_{A,\Pi} = 1$ si $b = b'$ (A gana)

Si $Pr[Mul_{A,\Pi}=1] = 0.5 + \varepsilon \Rightarrow \Pi$ es indisting.

Ejercicio

Los criptosistemas de flujo NO son seguros bajo múltiples cifrados

$c_1 = m_1 \oplus G(s)$

$c_2 = m_2 \oplus G(s)$

$\Rightarrow c_1 \oplus c_2 = m_1 \oplus m_2$

¿Similar al problema del One Time Pad con reuso de claves?
¡No es casualidad!

Definir un ataque que gane la prueba MUL

Solución

Definir un Algoritmo A que gane la prueba de múltiples cifrados

$A \rightarrow (m_{00}=0...0, m_{01}=0...0), (m_{10}=0...0, m_{11}=1....1)$

A obtiene c_1, c_2

$X = c_1 \oplus c_2 = m_1 \oplus m_2$

Si $x = 0...0 \rightarrow b=0$

Si no $\rightarrow b=1$

Necesidad de cifrado probabilístico

Si una función de cifrado es determinística, NO es segura bajo múltiples cifrados

El adversario anterior aplica a cualquier criptosistema donde $e_k(x)$ es constante

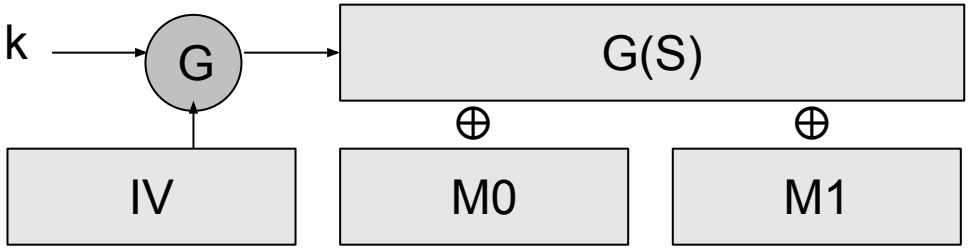
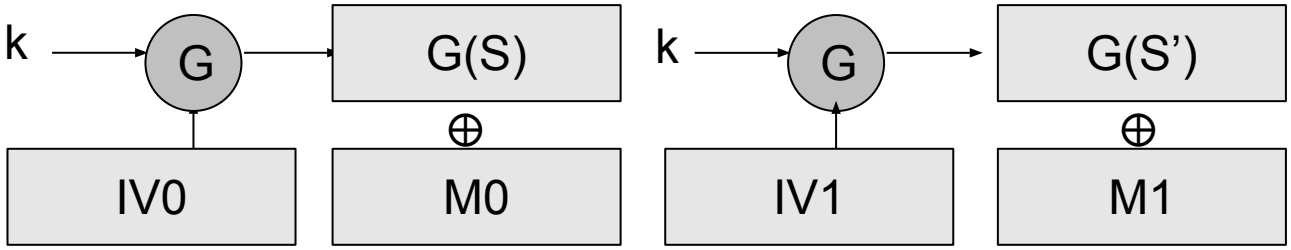
Evitar reutilizar la clave

Se agrega un valor a la función generadora

Dicho valor no deberá repetirse para una misma clave (se lo llama nonce o IV)

Dos formas:

Modo sincronizado (un unico IV)



Modo no sincronizado (un IV por mensaje)